Práctica 06 — Línea base, hardening, firewall y detección

Semana 6 — Fase 3: Defensa y hardening

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Duración	3 horas de laboratorio
Modalidad	4 grupos con roles rotativos
Entrega	GitHub del grupo, carpeta semana_06, antes del corte semanal
Instrumento	formativa

1 Objetivo

extgreater Aplicar endurecimiento de sistemas, configurar filtrado por defecto y comprobar la detección con Suricata.

2 Contenidos que se aplican

- Mínimo privilegio, usuarios del sistema y política de sudo.
- Permisos SUID, SGID y archivos con escritura global.
- SSH con claves, desactivación de contraseña y fail2ban.
- Parcheo, servicios innecesarios y CIS Benchmarks.
- Endurecimiento de systemd y perfiles de AppArmor.
- Línea base medible y verificación posterior.
- Política por defecto, nftables/ufw y segmentación.
- IDS/IPS con Suricata, firmas y lectura de alertas.
- TLS en tránsito y verificación de certificados.
- Comprobar que la detección ve el ataque frenado por la política.

3 Escenario

extgreater Cada grupo endurece el contenedor, aplica política de filtrado, repite el escaneo y analiza las alertas de Suricata.

4 Procedimiento

1. Documentar el estado inicial de doce controles antes de cambiar nada.
2. Aplicar los cambios de endurecimiento y reiniciar los servicios afectados.
3. Aplicar la política de filtrado en deny por defecto y permitir solo lo necesario.
4. Repetir el escaneo, verificar qué puertos dejaron de responder y clasificar las alertas de Suricata.
5. Justificar las excepciones de hardening y proponer una regla de detección específica.

5 Entregable

Auditor propio, hardening antes/después, reglas de firewall, comparativa de alcance y alertas de Suricata clasificadas.

6 Rúbrica de corrección

Criterio	Peso
Doce controles documentados y verificables	2,0
Auditor funcional con veredicto por control	2,0
Política de filtrado correcta y sistema operativo	2,5
Alertas de Suricata clasificadas y regla propuesta	2,5
Antes/después comparables y justificación de excepciones	1,0
Total	**10,0**

7 Contrato del script

Concepto clave

Todo script entregado imprime **un solo objeto JSON** por la salida estándar y devuelve un diccionario con estas claves. `status` vale `ok` o `error`; si es `error`, `errores` explica el motivo y el programa sale con código distinto de cero.

```
{
  "status": "ok",
  "objetivo": "172.28.0.10",
  "duracion_s": 12.4,
  "hallazgos": [
    {"puerto": 80, "servicio": "http", "version": "nginx"}
  ],
  "errores": []
}
```

Antes de empezar: confirma que el objetivo es un contenedor del laboratorio o un sistema con autorización escrita. Si no lo es, detente y consulta al docente: la práctica no se corrige sin ese requisito.